Bob's Big Brain: Operator-Grade System Analysis

Generated: 2026-08-07 Version: umbrella `4cffc31` (local) / `origin main 49a8d0d+ba15e80` · compiler (Compile) `v1.22.0` @ `cddb2fe` · registrar (Govern) `v0.8.0+29` unreleased @ `628c2257` · plugin (Package) `v1.2.0` @ `f684448` · qmd (Retrieve, pinned external) `2.5.3`

---

1. This system in 5 minutes

Bob's Big Brain is a local-first knowledge system built on one constraint, restated in every repo's own docs: **the model proposes; deterministic code owns durable state and control.** It has four layers, four separate git repos, and one piece of pinned open-source infrastructure it doesn't own:

- **Compile** (`bobs-big-brain-compiler`, npm `intentional-cognition-os`, internal shorthand **ICO**) — points at a folder of PDFs, Markdown, or web clips. A 6-pass Claude-driven compiler turns raw material into a cited Markdown wiki (concepts, sources, topics, contradictions, open questions), then hands off compiled candidates as a JSONL **spool**.
- **Govern** (`bobs-big-brain-registrar`, internal shorthand **INTKB**) — consumes that spool. A 9-rule deterministic policy engine (not the model) decides promote/flag/reject, writes to SQLite, exports curated Markdown, and appends a SHA-256 hash-chained receipt for every admitted fact. Its `qmd-adapter` package also owns retrieval fusion — RRF over qmd's lexical hits plus a native sqlite-vec + EmbeddingGemma-300M dense arm it added this cycle (see §3).
- **Retrieve** (`qmd`, by @tobi, pinned external dependency — not part of this codebase) — on-device BM25 lexical search only. Not forked; Govern's `qmd-adapter` invokes it as one arm of the fused search, the dense arm lives in Govern, not here.
- **Package** (`bobs-big-brain-plugin`, npm `governed-second-brain`) — the one installable Claude Code / Cowork MCP plugin, in two runtime modes: **local** (default, in-process, single trust domain) and **team** (proxies over Tailscale to one shared, governed brain).
- **Umbrella** (`bobs-big-brain-umbrella`, this repo) — no application code; it's the landing page, the cross-repo topology model (`system-graph.yml`, CI-gated against drift), and the operational glue (`bin/gsb`, the daily backup/compile/quality-digest cron jobs) that ties the other four together.

The differentiator the whole product is pitched on is **govern + receipts, not recall**: dedupe, policy, secret-detection, and promotion are deterministic code, and every admitted fact carries a verifiable, hash-chained trail back to its source. That chain is **tamper-evident, not tamper-proof** — a local writer with filesystem access can edit an event and re-hash the chain forward, and verification would still pass. Cross-actor detection of that kind of tampering requires the external git-anchor witness step, which is implemented and checkable via `ico audit verify` / `brain_audit_verify`. Keeping that distinction precise is not a nitpick — it is the product's whole trust model, and this document holds itself to the same standard the codebase enforces on its own docs (a CI-run forbidden-words lint on the umbrella README bans "tamper-proof," "immutable," "non-repudiation" for local mode, and "blockchain," and requires "append-only" claims to be qualified).

As of this audit, the system's newest and most consequential shipped change is **dense (semantic) retrieval going production-default** on both sides of the Govern↔Package boundary: registrar

PR #328/#334 wired `sqlite-vec` + EmbeddingGemma-300M into the API/edge-daemon/MCP-server/CLI, and plugin PR #60 (HEAD, 2026-08-04) carried the same dense arm into the plugin's **local mode**, closing the gap where local users would otherwise have stayed lexical-only forever. Both repos still have real, honestly-documented gaps: the registrar's staleness detector runs dry-run only (never deletes) — its last run was against a 10,190-active-memory snapshot; the live brain has since grown (see the umbrella's own `005-AT-ARCH` live-stats block for the current count), the compiler has 11 open draft PRs from a single day's fan-out that are not live, and three separate repos have README/CLAUDE.md version numbers that lag their own git history. None of this is hidden — it's exactly the kind of "what's proposed vs. what's live" distinction the product exists to make explicit, and this document tracks it the same way throughout.

---

2. Executive summary

What it does

Bob's Big Brain turns a pile of raw material (documents, notes, web clips) into a governed, queryable, citable knowledge base, and makes that knowledge base available inside Claude Code / Cowork as six-to-seven MCP tools depending on mode. A user (or a team, over Tailscale) captures material, the Compile layer proposes structured knowledge, the Govern layer decides — by code, not by the model's say-so — what's worth keeping, and the Retrieve layer answers queries with cited hits. The Package layer is the single distribution surface a human actually installs.

Operational status

- **Umbrella — System-graph fitness function (doc↔model drift gate)** — *Status:* **Shipped, live on main**. *Evidence:* `system-graph.yml` (50 nodes/50 edges, 44 derived/6 semantic), `.github/workflows/system-graph-sync.yml`
- **Umbrella — `bin/gsb` cross-repo helper + `repos.yml` manifest** — *Status:* **Shipped**. *Evidence:* `bin/gsb`, `repos.yml`
- **Umbrella — Daily brain backup (`bin/teamkb-backup.sh`)** — *Status:* **Shipped, deployed, running**. *Evidence:* cron 04:30, dual-recipient age encryption, restore-tested
- **Umbrella — Buzz-routed backup-failure alerting** — *Status:* **Source-shipped, explicitly NOT deployed**. *Evidence:* origin/main PR #76: "source-only until the reviewed deploy, canary, and rollback receipt exists"
- **Compile — Core CLI (16 commands), 6 compiler passes** — *Status:* **Shipped**. *Evidence:* `packages/cli/src/commands/*.ts`, `packages/compiler/src/passes/*.ts`
- **Compile — Provider-agnostic compile (7 built-in providers + custom)** — *Status:* **Shipped**. *Evidence:* `packages/types/src/providers.ts`
- **Compile — Governed freshness (incremental recompile + cost gate)** — *Status:* **Shipped**. *Evidence:* PR #154, `af3a7eb`, v1.21.0
- **Compile — Spool write-side to the Govern layer** — *Status:* **Shipped**. *Evidence:* `packages/kernel/src/spool.ts`, PR #142
- **Compile — 11-PR "l13" epic** (nightly-distiller alerts, write-lock, stale-mount freshness, honesty lint, quality gate) — *Status:* **Draft, unmerged, all opened same day (2026-08-02)**. *Evidence:* `gh pr list` — #185,187,190,192,193,195,197,199,201,203,205
- **Compile — v1.23.0 release-please PR** — *Status:* **Pending, not merged**. *Evidence:* tip `12890a5`, not ancestor of `origin/main`

- **Govern — Deterministic policy engine (9 rules)** — *Status:* **Shipped**. *Evidence:* `packages/policy-engine/src/rules/index.ts:14-24`
- **Govern — Fused lexical retrieval (qmd BM25 + native FTS5, RRF k=60)** — *Status:* **Shipped, production default**. *Evidence:* CHANGELOG [0.8.0]
- **Govern — Dense retrieval (sqlite-vec + EmbeddingGemma-300M)** — *Status:* **Shipped, production default as of this session**. *Evidence:* PR #328 (`46f6bf5`), wired into API, edge-daemon, MCP server, CLI
- **Govern — Reranker (Qwen3-0.6B cross-encoder)** — *Status:* **Shipped, opt-in, disabled by default**. *Evidence:* PR #305 — "measured, gate MISS, no default wiring"
- **Govern — Dense eval floor gate** — *Status:* **Hardened this session**. *Evidence:* PR #334 (`861ecc7`)
- **Govern — Staleness detector** — *Status:* **Dry-run only, not wired to any caller**. *Evidence:* PR #319 (`628c225`); zero non-test callers found
- **Govern — Team-bridge HTTP API (remote brain)** — *Status:* **Shipped, deployed**. *Evidence:* scrypt tokens, tailnet-bound
- **Retrieve — qmd 2.5.3 (pinned external, MIT, by @tobi)** — *Status:* **Live upstream dependency, not forked or vendored**. *Evidence:* pinned in `gsb.lock.json`, `package.json` devDep
- **Package — Local mode (6 tools)** — *Status:* **Shipped**. *Evidence:* `src/local-server.ts:157-558`
- **Package — Team mode (7 tools)** — *Status:* **Shipped**. *Evidence:* `src/remote-server.ts:384-801`
- **Package — Dense retrieval in local mode** — *Status:* **Shipped 2026-08-04 (PR #60, HEAD)**. *Evidence:* `src/local-server.ts:184`, `src/govern.ts:157`
- **Package — Session-end auto-capture hook** — *Status:* **Built, opt-in, off by default, not plugin-declared**. *Evidence:* `hooks/`, gated by explicit "I CONSENT" flow
- **Package — Automatic Cowork MCP registration** — *Status:* **Not shipped** ("Coming"). *Evidence:* README.md:194

Technology stack

Layer	Purpose	Tech	Why This (from source)
Compile	CLI	commander ^13	—
Compile	State DB	better-sqlite3 ^11.9	Deterministic local SQLite; synchronous API suits the kernel's non-throwing Result pattern
Compile	AI SDK	@anthropic-ai/sdk ^0.82	Native wire for the default provider; other wires go through a hand-rolled fetch adapter, no second SDK dependency
Compile	Validation	zod ^3.24	Runtime schema checking

Layer	Purpose	Tech	Why This (from source)
Compile	Mutation testing	Stryker ^9.6.1, kernel-only	Compiler talks to Claude through a mocked client — “mutation score there reflects mock-coverage not real behavior”
Govern	API	Fastify 5	—
Govern	Store	better-sqlite3, WAL mode, schema v9	Enum CHECK constraints backfilled onto a live legacy table
Govern	Validation	Zod 4	Migrated from Zod 3, CHANGELOG [0.5.0]
Govern	Retrieval fusion	RRF (k=60) over qmd BM25 + native FTS5 + sqlite-vec dense	Cheapest-sufficient path per the 2026-06-18 retrieval decision (see §Roadmap/decision log)
Retrieve	qmd (@tobilu/qmd)	2.5.3, MIT, pinned	“We pin @tobilu/qmd and ride upstream via Dependabot — we do not fork the search engine”
Package	Runtime	Node ≥20, TypeScript 5.7, ESM→CJS bundle	—
Package	MCP transport	@modelcontextprotocol/sdk ^1.29, stdio	—
Package	Bundler	esbuild ^0.28.1	Single-file self-contained bundle
Package	Native deps	better-sqlite3, fs-ext (flock), sqlite-vec	Can’t be bundled — compiled `.node` addons, externalized + vendored at build time
Package	Test	Vitest ^4.1.10, `node:test` (zero-dep)	—

Layer	Purpose	Tech	Why This (from source)
Umbrella	Model/rendering	Python 3.12 + PyYAML (unpinned)	No runtime framework; “this estate has been bitten repeatedly by maps that silently diverged from reality”
Cross-cutting	Task tracking	Beads (`bd`), Dolt-backed	Per-repo bead prefixes preserved across the 2026-07-19 rename (compile-then-govern / intentional-cognition-os / qmd-team-intent-kb)
Cross-cutting	Testing harness	@intentsolutions/audit-harness ^1.3.0	Standard Intent Solutions Testing SOP, installed in every repo
Cross-cutting	License	Apache-2.0 (all four repos)	Compiler relicensed MIT→Apache-2.0 2026-06-03, PR #129

---

3. Architecture

The critical path — one pipeline, four repos

```
USER / TEAMMATE
  |
  v
COMPILE (bobs-big-brain-compiler / ICO)
  L1 raw/        <- ico ingest (PDF/MD/web-clip adapters)
                    APPEND-ONLY*, deterministic
                    * hash-chained by protocol -- see the
                      forbidden-words note below
  |
  v
  disclosure.ts  <- ingest-time comp/PII reject guard
                    (choke point 1 of 3, company-wide)
  |
  v
  L2 wiki/       <- 6 compiler passes (Claude): extract ->
                    summarize -> synthesize -> link ->
                    contradict -> gap
```

```
                   RECOMPILABLE, probabilistic
                   receipt-gated (GATED_WIKI_DIRS) -- a
                   wiki file only becomes visible AFTER a
                   DB row + trace + audit JSONL +
                   rename-into-place, never before
  L3 tasks/<id>/ <- ico research (5-stage multi-agent,
                   Epic-9); PER-TASK, probabilistic
  L4 outputs/    <- render report/slides; PROMOTABLE,
                   deliberately NOT receipt-gated
  L5 recall/     <- flashcards, quizzes, retention scores;
                   ADAPTIVE, deterministic
  L6 audit/      <- trace JSONL + hash-chained audit log
                   (SHA-256, prev_hash per event)
  |
  v
  spool/         <- kernel/src/spool.ts, the
                   Compile->Govern handoff, JSONL,
                   schemaVersion-checked
  |
  v
GOVERN (bobs-big-brain-registrar / INTKB)
  claude-runtime <- secret scan, spool write
                   (choke point 2 of 3)
  |
  v
  policy-engine.PolicyPipeline.evaluate()
    the ONE decision point, two-phase:
    Phase 1: contradiction_check (flag-only, runs first)
    Phase 2: 8 remaining priority-ordered rules,
             reject short-circuits
    |
    +- outcome=rejected -> rejector.ts: audit event
    |    action='deleted', NOT promoted
    +- outcome=flagged  -> rejector.ts: SAME path as
    |    rejected -- no live "flag but promote" path
    |    exists today, despite a doc comment implying
    |    otherwise
    `- outcome=approved -> promoteCandidate() ->
         curated_memories row + 'promoted' event
         |
         v
         git-exporter -> kb-export/*.md (category-routed)
         |
         v
         qmd-adapter.index <- dense-index (bbb-embedder
           :8098, EmbeddingGemma-300M, sqlite-vec,
           opt-in reranker bbb-reranker :8097 available)
  |
```

```
  v
RETRIEVE (qmd, pinned external, by @tobi)
  On-device hybrid search: qmd BM25 + native FTS5 +
  sqlite-vec dense KNN, RRF-fused (k=60), freshness/
  category rerank, read-time sensitivity filter
  (confidential/restricted hidden from EVERY caller, no
  role parameter), tenant-scoped. NOT forked -- pinned
  devDependency.
  |
  v
PACKAGE (bobs-big-brain-plugin)
  src/index.ts -- mode dispatcher, reads TEAMKB_API_URL
  (env or ~/.teamkb/team.json fallback)
  |
  +- LOCAL MODE (default) -> src/local-server.ts,
  |    in-process, drives Govern kernel + qmd
  |    6 tools: brain_search / brain_status /
  |      brain_audit_verify (read)
  |      brain_capture / brain_govern /
  |      brain_transition (write)
  |    dense arm wired directly (PR #60) -- local mode
  |    never touches the HTTP API
  |
  `- TEAM MODE (TEAMKB_API_URL set) ->
       src/remote-server.ts, dependency-free HTTP proxy
       7 tools: adds admin-only brain_inbox /
         brain_approve / brain_reject
       no brain_govern -- govern runs server-side on
       the shared brain

UMBRELLA (bobs-big-brain-umbrella) -- orbits the whole
system
  system-graph.yml (the MODEL: 50 nodes, 50 edges, 44
  derived/6 semantic) <-> 020-AT-SMAP doc, gated by CI
  (system-graph-sync.yml). repos.yml (the INVENTORY).
  bin/gsb (cross-repo helper). bin/teamkb-backup.sh
  (daily, 04:30, dual-recipient age-encrypted,
  restore-tested -- the actual deployed backup for the
  whole live ~/.teamkb brain, not a docs artifact).
```

Stack table — why this, by layer

The per-package technology choices are listed in §2's Technology Stack table above (folded together to avoid repeating the same rows twice). The architecturally significant "why" decisions — provider-neutral compile, RRF-fused retrieval, the dual-mode plugin dispatch — are captured in §4's Decision Log rather than restated here, since they are tradeoffs, not just tech picks.

Dependency graph

Repo level (from `repos.yml` + `system-graph.yml`, 50 nodes / 50 edges, 44 mechanically-derived / 6 hand-curated semantic):

```
bobs-big-brain-umbrella  (map only, no code)
  |
  +-> bobs-big-brain-compiler (Compile)
  |     --spool--> bobs-big-brain-registrar (Govern)
  |                  --index--> qmd (pinned, @tobi,
  |                                  external)
  |
  `-> bobs-big-brain-plugin (Package)
        consumes both engines as build-time devDeps
        local mode: in-process
        team mode: HTTP proxy to registrar's apps/api

~/.teamkb/  <- the ONE live data directory (not a repo).
  Compile writes raw/wiki/spool here; Govern
  reads/writes teamkb.db + brain/.ico/state.db here;
  Package's local mode operates on this same directory
  in-process.
```

Package level, within Govern (registrar's own internal dependency-cruiser-enforced graph, CI job "Architecture rules"): `schema` → `common` → `{claude-runtime` → `policy-engine` → `api+curator; store` → `api+curator+git-exporter+reporting; qmd-adapter` → `api}`.

Package level, within Compile: `@ico/types` → `@ico/kernel` → `@ico/compiler` → `cli/benchmarks`, enforced by `dependency-cruiser` (`pnpm arch:check`, CI job `arch-check`).

Package's build-time-only coupling to Govern: the plugin's `devDependencies` link 8 registrar packages (`@qmd-team-intent-kb/{claude-runtime,common,curator,git-exporter,policy-engine,qmd-adap` via `link:../bobs-big-brain-registrar/*`. esbuild **inlines** these into the committed `plugin-runtime/governed-brain.cjs` bundle at build time; CI **strips** these devDeps before install (a fresh Actions runner cannot resolve a sibling checkout) — only the dedicated `anchor-conformance` CI job checks out the sibling repo to test against it.

The self-referential note: `system-graph.yml` models *itself* as a coordination-layer node with a `graph-sync-gate` edge pointing at it — "the model models its own drift guard," per the umbrella's own doc.

---

4. Design decisions & tradeoffs

Decision log

Provider registry (declarative record: wire, baseURL, keyEnv, defaultModel) for Compile

- **Over:** Base-URL hacks / Anthropic-only hardcoding
- **Because:** "the brain's compiler is model-neutral, the same way the eval platform is vendor-neutral" (`providers.ts:1-21`)

- **Cost:** A new provider is one registry entry, but every wire-format quirk (e.g. MiniMax's inline `<think>` blocks) still needs a bespoke adapter fix — happened once already, PR #183
- **Revisit when:** A provider ships a wire format neither `anthropic` nor `openai` covers

`stripThinkBlocks` as a linear scan, not a regex, in the shared openai-wire adapter

- **Over:** A `/<think>[\s\S]*?<\/think>/g` regex
- **Because:** "a quantifier applied to untrusted model output" is deliberately avoided elsewhere too — `claude-client.ts:258-260`
- **Cost:** Slightly more code, zero backtracking risk
- **Revisit when:** Never — hardening choice, not a stopgap

BM25-on-qmd shipped first, dense retrieval gated behind a measured Recall@10 floor — and the gate was met, so dense shipped exactly as scoped

- **Over:** Skipping qmd's 2.2 GB hybrid outright, or building semantic search speculatively
- **Because:** The 2026-06-18 decision doc set the gate at "BM25 below ~0.85 Recall@10 on a real labeled query set AND a genuine recall miss"; measured semantic Recall@10 was 0.3393 pre-dense, meeting the bar
- **Cost:** Dense adds a measurable per-query latency overhead and two new loopback services (`bbb-embedder` :8098, opt-in `bbb-reranker` :8097) that live outside the repo's own CI/deploy — see §10 for a caveat on where the specific latency figures originate
- **Revisit when:** If eval data ever shows dense isn't earning its complexity

Dense arm fails open on serving, fails loud (refuses a verdict) on eval

- **Over:** One fail-open path for both serving and eval
- **Because:** The same frozen index scored semantic Recall@10 0.9643 idle vs 0.7679 under load-9.5-on-8-cores with zero logged errors — silent fail-open made contention indistinguishable from a real regression
- **Cost:** Added an `onQueryDegraded` observer param threaded through `DenseConfig`
- **Revisit when:** —

Dual-mode plugin dispatch via lazy `await import()`, not two separate build targets

- **Over:** Always importing both server modules
- **Because:** Team mode must run from a marketplace clone with zero build step and must never pull in `better-sqlite3`
- **Cost:** Extra dispatch indirection; a stray static import in `remote-server.ts` is a silent regression, caught only by `smoke-team.mjs`
- **Revisit when:** Never — this is load-bearing to the whole distribution model

Native deps (better-sqlite3, fs-ext, sqlite-vec) externalized + vendored into `plugin-runtime/node_modules` at build time, not bundled or lazily npm-installed

- **Over:** Relying on a parent `node_modules`
- **Because:** A marketplace-copied `plugin-runtime/` has no parent tree; local mode failed outright with "not built for this machine" until this fix (CHANGELOG v1.1.0)

- **Cost:** First-run `npm ci` latency, plus a readiness-probe/provision-list pairing that must be manually kept in lock-step — sqlite-vec (PR #60) needed the exact same fix a second time because the probe originally checked only 2 of 3 modules
- **Revisit when:** Each new native dependency must repeat the pattern deliberately

`~/.teamkb/team.json` config-file fallback, mode 600, fail-closed on loose perms

- **Over:** Environment variables only
- **Because:** GUI/Dock-launched Claude never sources `~/.zshrc`, so a teammate who exported env vars there silently got an empty *local* brain that "succeeds" with zero results — the onboarding day-killer
- **Cost:** A second config path that must track env-var semantics exactly (mitigated by a shared `isConfigured` predicate)
- **Revisit when:** —

Sensitivity gate ships as policy `action:'flag'`, not `action:'reject'`, in Govern's recommended policy

- **Over:** Hard `reject`, like secret_detection/content_length/tenant_match
- **Because:** Deliberately conservative-by-default: "an operator can tighten a flag to a reject deliberately"
- **Cost: The net effect is currently identical to reject anyway** — `curator.ts:191-199` routes both `flagged` and `rejected` outcomes through the same reject path, so today there is no live "flag but still promote" path for any rule. This is a real gap between the doc-comment's stated intent and the shipped behavior — not a design win, a finding (see §8)
- **Revisit when:** Wire a genuine flag-and-promote path, or correct the doc comment to match reality

Staleness detector ships dry-run-only, deliberately not wired to any writer

- **Over:** Wiring the apply step immediately
- **Because:** The dry run against the live 10,190-memory brain found 1,025 candidates (10.06%) — but also 154 historical-record false positives needing human judgment on precision before any deletion path runs. "Shipping the apply step on these rules would retire ~1,000 memories on a rule set that has not earned it."
- **Cost:** Every stale-content problem in the live brain persists until this ships
- **Revisit when:** Gated behind a receipted-rules requirement not yet built

Origin tokens (HMAC-SHA256 over candidateId+tenantId+capturedAt) mint at `brain_capture`, verified before promotion

- **Over:** No write-time provenance at all
- **Because:** Proves WHERE a capture came from
- **Cost:** Stated explicitly, not hidden: does NOT prove content truth — "an authenticated insider… can still poison L2/L3 content with validly-attested captures." This is a permanent, acknowledged limitation
- **Revisit when:** n/a — accepted residual risk

What was deliberately not built

- **Remote/sync, multi-user, and a plugin system** (README Phases 3-5) — "deliberately deferred to keep v1 local-first and inspectable." No customer-facing chatbot use case, no team-shared Slack-drop use case.
- **A daemon in the Package layer** — explicitly avoided: "no daemon, no HTTP, no network, no API key" in local mode. Govern runs synchronously on-demand, hand-wiring the same sequence the registrar's edge-daemon runs per cycle, just without the loop.
- **Cross-actor detection of local-mode tampering** — genuinely out of scope for local mode; the external git-anchor witness is the mitigation, and even that is framed honestly as `UNPUSHED_LOCAL_WITNESS` when there's no remote to anchor against.
- **Channel attestation in local mode (v1)** — "the box is one trust domain: any process that can read the [origin] secret can claim any channel."
- **Per-role or per-audience query-time filtering** in Govern — confirmed by code, not absence of evidence (see §9). Retrieval segments a shared brain on exactly two axes: tenant (hard, server-bound) and sensitivity classification (binary, global, identical for every caller regardless of role).
- **An apply step for the staleness detector** — dry-run only, on purpose (see decision log above).
- **Mutation testing on the Compile package** — deliberately scoped to the kernel only; the compiler talks to Claude through a mocked client, so "mutation score there reflects mock-coverage not real behavior."
- **Automatic Cowork MCP registration** in Package — README literally says "Coming," no implementation found.
- **Cross-source `compilation_sources` junction population** in Compile — the schema table exists, no writer exists yet; incremental-compile's "affected set" logic is deliberately conservative (fails toward recompiling, not toward staleness) specifically because of this gap.
- **A distributed multi-node brain merge (EPIC 1, Dolt-based)** — foundation-only primitives shipped (content-derived UUID v5, Ed25519-signed DAG anchors), not the actual merge UX. Demand-gated, not scheduled.
- **`--check-local` in Umbrella's CI** — a GitHub runner has none of the systemd units/crontab/paths it would need to check, and would "fail vacuously," so that verification mode stays dev-box-only, permanently.

Assumptions the architecture rests on

1. **The model never writes durable state, audit, or promotion tables directly** — restated in every repo's README and CLAUDE.md; the single hardest constraint in the system.
2. **A "receipt" (DB row + trace + audit JSONL + rename-into-place) always precedes visibility of any wiki file** — enforced two-sided (pre- and post-hoc reconcile) in Compile's `reconcile.ts` (`GATED_WIKI_DIRS`), in lockstep with Compile's `spool.ts` (`WIKI_DIRS`) and Govern's `promotion.ts` (`TYPE_DIRECTORY_MAP`) — drift among these three would silently break the receipt guarantee, and nothing mechanically enforces that the three lists stay in sync.
3. **Raw and derived content are strictly separate with provenance from the first byte** — a non-negotiable principle in Compile's CLAUDE.md.
4. **Umbrella's `system-graph.yml` "evidence" field is truthfully re-verified by a human at edit time** — CI only checks that the field is *present*, never that it's *true*, except for

derived-tier nodes via the dev-box-only `--check-local` mode. The 6 `semantic`-tier edges have no mechanical check at all, ever.

5. **A marketplace-copied plugin has no parent `node_modules` tree** — the entire native-dependency-vendoring architecture (§Decision Log) rests on this being true; it was learned the hard way (v1.1.0, then again for sqlite-vec in PR #60).
6. **Single trust domain in local mode** — role is always "owner"/admin because "there is no boundary to protect on a personal machine." Team mode assumes the brain API's network reachability is gated by Tailscale, not the application itself.

---

5. Directory structure

Layout (four repos + one live-data directory)

```
~/000-projects/
+-- bobs-big-brain-umbrella/  (public, intent-solutions-io)
|     landing + working surface
|     README.md, CHANGELOG.md, repos.yml, system-graph.yml
|     000-docs/  scripts/  bin/  changelogs/
|     .github/workflows/  .beads/  assets/
+-- bobs-big-brain-compiler/  (public, jeremylongshore)
|     Compile
|     packages/{types,kernel,compiler,cli,benchmarks}
|     plugin/  evals/  dogfood/  000-docs/
|     .github/workflows/  .beads/
+-- bobs-big-brain-registrar/  (public, jeremylongshore)
|     Govern
|     packages/{schema,common,claude-runtime,
|       policy-engine,store,qmd-adapter,
|       git-exporter,reporting}
|     apps/{api,curator,git-exporter,edge-daemon,
|       mcp-server}
|     000-docs/  .github/workflows/
+-- bobs-big-brain-plugin/  (public, jeremylongshore)
|     Package
|     src/{index,local-server,remote-server,mode,
|       config,govern,team-config}.ts
|     plugin-runtime/  hooks/
|     skills/{brain,brain-save}/  smoke/  scripts/
|     .claude-plugin/
`-- ~/.teamkb/  (NOT a repo) -- the one live brain
      teamkb.db  (Govern's store, schema v9)
      brain/.ico/state.db  (Compile's state)
      brain/raw/  brain/wiki/  brain/audit/
      brain/spool/  spool/  <- two DIFFERENT spool
        dirs, see Appendix A (Glossary)
      team.json  (mode 600)
      origin-secret (mode 600)
```

```
tokens.json (SOPS-covered secret)
backups/  (age-encrypted, dual-recipient,
  pushed off-host by the umbrella's cron)
```

Load-bearing files, by layer

Umbrella:

- **`system-graph.yml`**
  - *Role:* The topology MODEL (50 nodes/50 edges)
  - *Why it breaks everything:* Fails the `system-graph-sync` CI gate closed on any bad edit; the sole source of truth for cross-repo dependency claims
- **`scripts/render-system-graph.py`**
  - *Role:* Sole writer of the rendered topology doc
  - *Why it breaks everything:* If it silently mis-renders, the doc could look plausible without reflecting the YAML — mitigated only by the CI byte-comparison, not by inspection
- **`scripts/lint-forbidden-words.sh`**
  - *Role:* The entire brand-honesty enforcement mechanism
  - *Why it breaks everything:* Hash-pinned via `.harness-hash`; fails `HARNESS_TAMPERED` (exit 2) if edited without re-pinning
- **`bin/teamkb-backup.sh`**
  - *Role:* The actual, deployed daily backup of the entire live ~3.7 GB brain
  - *Why it breaks everything:* A bug here is a real data-loss risk across all four repos, not a docs risk

Compile:

- **`packages/types/src/providers.ts`**
  - *Role:* Provider registry (7 built-ins + custom + aliases)
  - *Why it breaks everything:* Every LLM call resolves through `resolveProvider/resolveApiKey/resolveM` here
- **`packages/compiler/src/api/claude-client.ts`**
  - *Role:* The single OpenAI-wire adapter shared by every non-Anthropic vendor
  - *Why it breaks everything:* A regression here silently corrupts compile output for MiniMax/DeepSeek/Groq/NVIDIA/local simultaneously
- **`packages/compiler/src/cost-gate.ts`**
  - *Role:* Governed-freshness cost gate
  - *Why it breaks everything:* The only thing standing between incremental on-push compile and unbounded inference spend at ~40 pushes/day
- **`packages/kernel/src/spool.ts`**
  - *Role:* The Compile→Govern write side (EPIC 0)
  - *Why it breaks everything:* If this breaks, nothing compiled here ever reaches the Govern layer
- **`packages/kernel/src/disclosure.ts`**
  - *Role:* Ingest-time comp/PII reject guard
  - *Why it breaks everything:* Source-side choke point 1 of a 3-point company-wide rule against ever storing PII/comp data

Govern:

- **`packages/policy-engine/src/pipeline.ts`**

- *Role:* The ONE promotion/flag/reject decision point
    - *Why it breaks everything:* Every governance guarantee in the product's pitch is void if this breaks
- **`packages/store/src/schema.ts`**
    - *Role:* DDL + 9 migrations, enum CHECK constraints
    - *Why it breaks everything:* Last-line defense against enum-smuggled disclosure-shaped strings in governed columns
- **`apps/api/src/middleware/{tenancy-guard,write-gate}.ts`**
    - *Role:* Server-side tenant binding + admin-only write boundary
    - *Why it breaks everything:* The only server-side enforcement of both isolation guarantees
- **`apps/api/src/auth/token-registry.ts`**
    - *Role:* scrypt-hashed bearer tokens, tenant allowlists, revocation
    - *Why it breaks everything:* All auth resolves through `InMemoryTokenRegistry.resolve()`
- **`packages/qmd-adapter/src/config.ts`**
    - *Role:* `getDefaultDenseConfig()`
    - *Why it breaks everything:* Single production on/off switch for dense retrieval across API, edge-daemon, MCP server, and CLI

Package:

- **`src/index.ts` + `src/mode.ts:47-57`**
    - *Role:* Mode dispatcher + its extracted, unit-tested predicate
    - *Why it breaks everything:* Wrong mode selection silently queries the wrong brain
- **`plugin-runtime/governed-brain.cjs`**
    - *Role:* The committed, 44,710-line shipped bundle
    - *Why it breaks everything:* Must be rebuilt + committed with every `src/` change — a manual, unenforced discipline; a stale bundle silently ships old behavior
- **`plugin-runtime/bootstrap.cjs`**
    - *Role:* Marketplace-safe launcher, native-dep readiness probe
    - *Why it breaks everything:* Local mode fails hard without it on a copied install
- **`gsb.lock.json`**
    - *Role:* Known-good version tuple across plugin×compile×govern×retrieve×natives
    - *Why it breaks everything:* `smoke/check-lock.mjs` hard-fails CI on any manifest drift
- **`build.mjs`**
    - *Role:* esbuild config + native-dep externals list
    - *Why it breaks everything:* A missing external here breaks native-addon resolution — exactly the sqlite-vec root cause PR #60 fixed

---

6. Getting started

Prerequisites

Prereq	Needed For	Why
Node ≥20	All four repos	Shared engine floor, `gsb.lock.json:38`

Prereq	Needed For	Why
pnpm 10.8.1 (Compile) / pnpm (Govern)	Building Compile/Govern from source	Pinned `packageManager` field
An LLM API key (Anthropic, DeepSeek, MiniMax, Groq, NVIDIA, or a custom OpenAI-wire endpoint)	Compile	`ico compile` calls out; keyless local/custom providers are also supported
C/C++ toolchain	Package (first local-mode start)	`better-sqlite3` native build fallback if no prebuilt binary matches the host
`qmd` 2.x on PATH	Retrieval	Local retrieval degrades gracefully (not broken) if absent — capture/govern/audit still complete
Sibling checkout of `bobs-big-brain-registrar`, built	Package, only if building the plugin from source	Not needed to run the shipped npm bundle

Zero to running (the actual user path — install the plugin)

```
npx governed-second-brain init <folder> --index-only     # zero-egress, no LLM calls
# OR, for a full compiled brain: set DEEPSEEK_API_KEY in your shell first, then
npx governed-second-brain init <folder>
# This installs native deps, builds ~/.teamkb, and
# auto-registers the MCP server via `claude mcp add`.
```

Zero to running (operating the Compile engine directly)

```
npm install -g intentional-cognition-os
export ANTHROPIC_API_KEY=<your-anthropic-api-key>
ico init my-research
ico mount add papers ~/Documents/papers --workspace my-research
ico ingest ~/Documents/papers --workspace my-research
ico compile all --workspace my-research
ico ask "..." --workspace my-research
```

Building from source (any of the three code repos)

```
# pick one:
git clone https://github.com/jeremylongshore/bobs-big-brain-compiler.git
git clone https://github.com/jeremylongshore/bobs-big-brain-registrar.git
git clone https://github.com/jeremylongshore/bobs-big-brain-plugin.git

cd <the repo you cloned> && pnpm install && pnpm build
```

Common setup problems

Problem	Symptom	Fix
Global `ico` CLI symlink orphaned by the 2026-07-19 repo rename	`ico` command not found despite npm claiming it's installed; `/usr/bin/ico` is a dangling symlink	`npm install -g intentional-cognition-os` again, or repoint the symlink manually — no automated fix shipped yet
`better-sqlite3` "not built for this machine"	Local plugin mode fails on first start after a marketplace/copied install	Fixed for the general case by `bootstrap.cjs`'s first-run `npm ci`; if it still happens, verify `nativeDependenciesReady()` is probing all 3 native modules, not 2
GUI/Dock-launched Claude silently runs local mode despite team env vars being set	An "empty but successful" local brain with zero results, no error	`~/.teamkb/team.json` (mode 600) fallback exists precisely for this — write it directly rather than relying on shell-sourced env vars
"No compiled knowledge found"	`ico ask` returns nothing	Workspace hasn't been compiled yet — run `ico compile all`
"Workspace database is locked"	Compile command hangs or errors	A concurrent `ico` process is holding the SQLite lock — check with `lsof` on `state.db`
Dense retrieval silently returns lexical-only results	No error, just degraded relevance	The `bbb-embedder` (:8098) loopback service isn't running — dense fails open by design, but silently; check `systemctl --user status bbb-embedder`
Stale local git checkout describes the system inaccurately	An audit or session reasoning from local `main` is many merged PRs behind `origin/main` (this happened in this very audit, on both umbrella and compiler)	`git fetch && git log <local>..origin/main` before trusting any local HEAD-based claim

7. Operations

Command map, by layer

Umbrella:

```
./bin/gsb map      # topology + per-repo branch/dirty state
./bin/gsb status   # cross-repo branch/dirty/ahead-behind
./bin/gsb sync     # clone missing sub-repos, pull --rebase the rest

# regenerate the topology doc from the YAML:
python3 scripts/render-system-graph.py --write
# CI-equivalent local check:
python3 scripts/render-system-graph.py --check
# dev-box-only box-state verification:
python3 scripts/render-system-graph.py --check-local

# required before any brand-surface edit:
bash scripts/lint-forbidden-words.sh README.md
```

Compile:

```
pnpm build / pnpm test / pnpm test:coverage / pnpm lint / pnpm typecheck
pnpm mutation          # stryker, kernel-only scope
pnpm arch:check        # dependency-cruiser
pnpm audit:harness / pnpm audit:escape
pnpm cli:smoke         # builds artifact smoke: --version + --help
```

Govern:

```
pnpm install / pnpm validate      # format:check + lint + typecheck + test
pnpm test:coverage / pnpm test:integration / pnpm test:mutation
pnpm crap                          # complexity gate
pnpm harness-pin                   # policy hash-pin verify
pnpm eval:retrieval / pnpm eval:onboarding
pnpm reindex / pnpm search-canary / pnpm bbb-qmd
```

Package:

```
npm run build            # node build.mjs - esbuild bundle + vendor natives
npm run typecheck        # or: npm run typecheck:ci
npm run lint
npm run test              # or: npm run test:coverage
npm run verify-anchors    # standalone anchor-log verifier
node smoke.mjs             # full-chain local smoke, drives the COMMITTED bundle
node smoke-team.mjs         # stubbed-API team-mode smoke
```

CI/CD, by repo

Umbrella - *Key workflows:* `system-graph-sync.yml`, `docs-honesty.yml`, `shellcheck.yml`, `aggregate-changelogs.yml` (weekly), `minimax-review.yml` (advisory only) - *Notes:* Docs/tooling only, no build/deploy — "deployment" here is the daily cron on the dev box, not CI

Compile - *Key workflows:* `ci.yml` (13 jobs: lint, typecheck, audit, test, coverage, format, gitleaks, harness-verify, arch-check, cli-smoke, audit-chain-verify, plus 2 plugin-script jobs), `codeql.yml`, `mutation.yml`, `nightly-smoke.yml` (key-free, 07:23 UTC), `release-please.yml` - *Notes:* Deployment = `npm publish` via release-please tag trigger — no hosted service

Govern - *Key workflows:* `ci.yml` (`validate`, `moat-evals`, `retrieval-eval`, `integration`), `security.yml` (npm audit, gitleaks, Semgrep), `nightly.yml` (04:00 UTC, full evals + search-health canary), `seam-independence.yml` (3 gates: delete-Compile-and-still-govern, swap-model-zero-migration, model-free-receipts), `release.yml` (cosign keyless OIDC + SLSA L3 provenance for the edge-daemon container) - *Notes:* The only repo with a real deployed service surface (`apps/api`, edge-daemon, embedder/reranker sidecars)

Package - *Key workflows:* `ci.yml` (quality + anchor-conformance), `smoke.yml` (drives the committed bundle, not source), `release.yml` (npm publish w/ provenance, guards tag==package.json version), `minimax-review.yml` - *Notes:* Deployment = `npm publish`; the "deploy" a user experiences is `npx governed-second-brain init`

Deployment

There is no single "the system deploys here." Three different deployment stories coexist:

1. **npm publish** (Compile, Package) — versioned tags trigger `release-please` → `npm publish`. No hosted runtime.
2. **Systemd-hosted services** (Govern) — `apps/api` (the team-bridge Fastify API, tailnet-bound), plus two loopback-only sidecars: `bbb-embedder.service` (:8098, SHA-256-pinned llama.cpp + EmbeddingGemma-300M-Q8_0.gguf, `MemoryMax=3G`) and `bbb-reranker.service` (:8097, opt-in). These are NOT part of Govern's own CI or release workflow — an operator who clones fresh and runs `apps/api` without them running will silently get lexical-only results (fail-open, but silent).
3. **A daily cron pipeline** (Umbrella) — `teamkb-compile-daily.sh` (03:30), `teamkb-backup.sh` (04:30), `teamkb-quality-digest.sh` (nightly), `teamkb-systemmap.sh` (regenerates the live-stats doc block). These are the umbrella's real operational surface — bash scripts run outside any repo's own CI, deployed to `~/bin` from the umbrella's canonical `bin/` copies.

Monitoring & alerting

- **Umbrella's backup cron** now has a "route failures through governed Buzz alerting" change **shipped to source but explicitly not yet deployed** (origin/main PR #76: "source-only until the reviewed deploy, canary, and rollback receipt exists"). Treat any claim that backup failures currently page anyone as unverified until that deploy happens.
- **Govern's nightly workflow** (`nightly.yml`, 04:00 UTC) runs a search-health canary and a corpus-accounting guard as its monitoring surface — CI-based, not a running daemon's alerting.
- **Compile's `nightly-smoke.yml`** runs cross-repo deterministic smoke daily without needing an API key (skips the three Claude-calling stages) — a canary for structural breakage, not for LLM-provider health.
- No repo in this system ships a dashboard; observability is CI job status + the audit JSONL trail + `bd doctor`/`bd status` on the beads trackers.

Incident response

Scenario	Where to look first
Dense retrieval silently degraded to lexical-only	`bbb-embedder` service status; the dense arm's `onQueryDegraded` observer output (PR #334)
A promoted memory turns out to be wrong/poisoned	Check its origin token (proves provenance, not truth) via `brain_audit_verify`; escalate to a human — origin tokens do not prove content is correct
Umbrella backup cron fails	`~/.teamkb/backups/`, the `.ok` gate file, `bin/teamkb-backup.sh` logs — note Buzz-routed paging for this is source-shipped but not yet deployed (see above)
Compile CLI globally broken (`ico: command not found`)	Check `/usr/bin/ico` for a dangling symlink from the 2026-07-19 rename; reinstall globally
Plugin behaving differently than `src/` suggests	Check whether `plugin-runtime/governed-brain.cjs` was rebuilt+committed after the last `src/` change — this is a manual discipline, unenforced by any hook
Audit chain verification fails	`ico audit verify` / `brain_audit_verify` / `scripts/verify-anchors.mjs` (standalone, zero-dependency) — distinguish a genuine tamper-evidence trip from a chain-continuity bug before assuming compromise

---

8. Things that will bite you

Ranked by likelihood × impact across the whole system.

1. **Local git checkouts drift silently behind `origin/main` — confirmed live, twice, in this very audit.** *Symptom:* an audit, a session, or a teammate reasoning from a local `main` branch describes work that's already been superseded (umbrella's local HEAD was 2 commits behind origin, including a factual-correction PR; compiler's local branch was ~18 merged PRs stale). *Cause:* nothing fast-forwards local `main` automatically, and no session-start hook checks for this. *Fix:* `git fetch && git log <local>..origin/main` before any repo-wide claim. *Prevention:* none shipped anywhere in this system yet — this is a process gap, not a tooling one.

2. **A `flag` policy outcome behaves identically to `reject` in Govern today, contradicting its own doc comment.** *Symptom:* content the recommended policy documents as "flag… never blocks a legitimate promotion" (sensitivity_gate, `recommended-policy.ts:103-109`) is in fact never promoted — `curator.ts:191-199` routes both `flagged` and `rejected` outcomes through the same reject path, writing the same `action:'deleted'` audit event. *Cause:* the curator was never wired with a genuine

flag-and-promote path. *Fix:* either build that path, or correct the doc comment so it matches shipped behavior. *Prevention:* a test asserting "a flagged candidate is still promoted" would have caught this at write time; none currently exists.

3. **Three repos have stale version/status claims in their own top-level docs.** Registrar's README says v0.7.0 when the actual state is v0.8.0+29 unreleased commits; registrar's CLAUDE.md still describes a "Grade C (~65/100), 2026-04-21 baseline" testing posture and "harness pending install" when the harness has been fully wired since v0.6.0; registrar's CLAUDE.md says "8 deterministic rule evaluators" when the registry has 9 (`contradiction_check` was added by PR #288). Compiler's `TEST_AUDIT.md` is dated 2026-05-19, nearly 3 months stale relative to this audit, predating PRs #145 through #183+ and the entire 11-PR l13 epic. Plugin's `AGENTS.md` retrieval-roadmap section still describes dense retrieval as "roadmapped, not shipped… eval-gated" when PR #60 shipped it default-on in local mode. Umbrella's `CHANGELOG.md` has zero entries for its two most recent merged PRs (#78, #79). *Fix for all of these:* a documentation pass is overdue across the whole system, not any single repo. *Prevention:* only umbrella has a mechanical drift gate (`system-graph-sync.yml`) and it covers exactly one doc — the pattern hasn't been extended to CLAUDE.md/README version stamps anywhere.

4. **11 open draft PRs in Compile, all opened the same day (2026-08-02), none merged** — a substantial epic's worth of near-term architecture (nightly-distiller alerting, write-lock serialization, stale-mount freshness, honesty lint, quality gate, batch receipts, incremental spool bound, reindex-heal) sits in draft. *Symptom:* anyone describing that work as live is wrong. *Fix:* check `gh pr list --state open` before citing any of it as current state.

5. **Dense retrieval fails open silently when its loopback services aren't running.** *Symptom:* no error, just quietly worse (lexical-only) search results, in both Govern's API/MCP-server/CLI paths and, since PR #60, the plugin's local mode too. *Cause:* `bbb-embedder`/`bbb-reranker` are systemd services outside any repo's own CI or deploy pipeline — an operator running a fresh clone without them gets degraded results with no signal. *Fix:* check `systemctl --user status bbb-embedder`. *Prevention:* the eval-gate hardening in PR #334 added `onQueryDegraded`/self-evidencing fields specifically to make contention/failure visible in *evals* — but that doesn't page anyone in live serving.

6. **The `plugin-runtime/governed-brain.cjs` bundle can lag `src/` with zero enforcement.** *Symptom:* the shipped plugin behaves differently than the source suggests. *Cause:* "rebuild + commit it with any src/ change" is a comment-only discipline (`AGENTS.md:69`), not a git hook or CI gate. *Fix:* always rebuild before committing a `src/` change; the smoke suite drives the *committed bundle*, so a forgotten rebuild is at least eventually visible in CI — but not at commit time. *Prevention:* none shipped; a pre-commit hook comparing bundle mtime to `src/` mtimes would close this.

7. **A new native dependency requires manually repeating a 3-part pattern (externals list, vendor package.json, readiness probe) — and the readiness probe has already been caught missing an entry once.** *Symptom:* local mode dies at adapter init with `MODULE_NOT_FOUND` despite `bootstrap.cjs` claiming readiness. *Cause:* `nativeDependenciesReady()` originally probed only 2 of 3 native modules when sqlite-vec was added (PR #60 fixed this specific instance). *Fix:* verify all three call sites (`build.mjs` externals, `plugin-runtime/package.json` provision list, `bootstrap.cjs` probe) stay in lock-

step for any future 4th native dep. *Prevention:* no test enforces this pairing beyond the smoke suite that caught it once.

8. **Umbrella's `system-graph.yml` semantic-tier edges (6 of 50) have zero mechanical re-verification, ever.** *Symptom:* a stale hand-curated claim about system behavior can sit unnoticed indefinitely — this is exactly the class of bug PR #79 fixed after it was caught. *Cause:* only `derived`-tier edges get a `--check-local` verification pass, and that pass is dev-box-only, never run in CI. *Fix:* periodic human re-audit of the 6 semantic edges. *Prevention:* none mechanical; this is accepted-by-design, not a bug, but it's a real ongoing risk surface worth tracking.
9. **The staleness detector's precision problem is real, live, and unresolved.** *Symptom:* 154 of 1,025 flagged candidates (15%) in the one dry run performed were historical-record false positives that an exemption rule caught. *Cause:* the rule set hasn't earned an apply step yet — this is stated honestly in the shipping commit message, not swept under the rug. *Fix:* none pending; this is deliberately paused work, not a bug to chase. *Prevention:* n/a — correctly gated.
10. **Cron's minimal `PATH` (a general estate-wide gotcha, not unique to this system, but directly relevant to the umbrella's deployed scripts)** — any of the umbrella's cron-deployed scripts (`teamkb-backup.sh`, `teamkb-compile-daily.sh`) that shell out to tools living outside `/usr/bin:/bin` can fail silently unless they explicitly export `PATH`. This is a documented, previously-realized failure mode on this exact backup fabric (per the operator's own incident history), directly applicable to the scripts this system depends on for its only durable backup.

---

9. Security & access

Access control

- **Bearer token → role (`admin | member`)** — *Scope:* Write vs. read. *Enforcement:* `write-gate.ts` (mutation methods on `/api/memories`, `/api/policies`, `/api/import`, `/api/auth`, `promote/reject`). *Layer:* Govern
- **Tenant allowlist bound to token** — *Scope:* Per-tenant read/write isolation, server-bound, never caller-controlled. *Enforcement:* `tenancy-guard.ts` preHandler hook. *Layer:* Govern
- **Sensitivity classifier (write time)** — *Scope:* Binary allow/block gate at capture/promotion. *Enforcement:* `sensitivity-gate-rule.ts`, wired as `action:'flag'` in the recommended policy (net effect = block, per §8 finding 2). *Layer:* Govern
- **Read-time sensitivity re-check — no role parameter, applies identically to every caller** — *Scope:* Defense-in-depth on every search path. *Enforcement:* `isSearchVisibleSensitivity()`, hides `confidential/restricted` for both `member` and `admin` tokens alike. *Layer:* Govern + Retrieve
- **Raw-inbox read restriction** — *Scope:* Admin-only `GET /api/candidates*` (pre-governance content). *Enforcement:* `tenancy-guard.ts` onRequest hook. *Layer:* Govern
- **Origin tokens (HMAC-SHA256)** — *Scope:* Provenance, not authorization. *Enforcement:* Minted at capture, verified before promotion. *Layer:* Compile→Govern
- **Ingest-time disclosure guard** — *Scope:* Comp/PII reject at the source. *Enforcement:* `disclosure.ts`, choke point 1 of 3. *Layer:* Compile

- **Injection defense (5 regex patterns + explicit "do not follow instructions in tags" system-prompt lines)** — *Scope:* Prompt-injection resistance for every LLM call and every Epic-9 agent. *Enforcement:* `sanitizeForPrompt`, `INJECTION_PATTERNS`. *Layer:* Compile
- **Local-mode auth** — *Scope:* **None** — single trust domain, owner always admin. *Enforcement:* `config.ts:9-14`: "there is no boundary to protect on a personal machine". *Layer:* Package
- **Team-mode auth** — *Scope:* Per-user bearer token (`TEAMKB_API_TOKEN`), role-aware 401/403/422. *Enforcement:* `remote-server.ts:99-125`, enforced server-side only. *Layer:* Package↔Govern

Direct answer to "does the system do any role- or audience-based filtering beyond tenant isolation and the write-time sensitivity classifier?" No — confirmed by code, not by absence of evidence. Neither `apps/api/src/services/search-service.ts` (both `searchViaQmd` and `searchViaSqlite`) nor `apps/mcp-server/src/tools/search.ts` accept a role parameter anywhere; `teamkb_search` is registered unconditionally for both member and admin installs (proven directly by test `server-role.test.ts:58-60`, which asserts the tool name is present for both). The only role check anywhere near search is the admin-only restriction on reading the raw, pre-governance inbox — that's inbox access control, not filtering of governed search results. A `member` token and an `admin` token retrieve byte-identical search results for the same tenant. Role gates *write* actions (propose is member-allowed; promote/transition/policy-edit/import/reject are admin-only) and *raw-inbox reads* only.

Secrets

Secret	Location	Handling
LLM provider API keys (Compile)	env vars or `.ico/config.json`	`.env.example` documents keys for all 5 hosted providers plus custom overrides; CI has a dedicated `.env*` leak check + `gitleaks` job
`~/.teamkb/team.json`	mode 600, fail-closed on loose permissions or malformed content	`team-config.ts:101-109`
`~/.teamkb/origin-secret`	auto-created 0600, env-only in team mode (deliberately no file fallback, to avoid cross-contamination with a local-mode secret on the same box)	`remote-server.ts:48-53`
`~/.teamkb/tokens.json`	Treated as a SECRET → SOPS-covered at the estate level (per umbrella architecture doc)	—

Secret	Location	Handling
Registrar bearer tokens	scrypt-hashed at rest (N=2^14, salted), constant-time comparison with a deliberate length-mismatch dummy compare to avoid a timing side-channel	`token-registry.ts:78-85`
Edge-daemon container image	Cosign keyless (OIDC) signing + SLSA L3 provenance	`release.yml`, via the slsa-github-generator action
npm package publishes (Compile, Package)	Provenance-attested (`npm publish --provenance`)	`release.yml` in both repos

Honest security assessment

- **CodeQL is a required check** in Compile and actively catches real issues — e.g., a confirmed fix for a TOCTOU race (`js/file-system-race`) in `parseChangedList`.
- **OSV Scanner replaces `pnpm audit`** (retired by npm 2026-04-15) in Compile, reading `pnpm-lock.yaml` directly and failing on HIGH/CRITICAL.
- **Weekly gitleaks + Semgrep, nightly npm audit** in Govern.
- **The audit chain is tamper-evident, not tamper-proof.** A local writer with filesystem access can edit an event and re-hash the chain forward; `ico audit verify` / `brain_audit_verify` would still pass. Cross-actor detection of that kind of tampering requires the external git-anchor witness step, which is implemented and checkable — `brain_govern` commits the chain head, `ico audit verify` cross-checks it. Three of the four repos' brand-surface docs correctly use "tamper-evident." The registrar has several unqualified "immutable" uses describing the audit trail in internal docs/code comments and its public OpenAPI spec (CLAUDE.md:124, `openapi.ts:36`, `audit-event.ts:5`, `audit-repository.ts:107`, `routes/audit.ts:22`) — a real, uncaught violation, since the mechanical forbidden-words lint (`docs-honesty.yml / lint-forbidden-words.sh`) exists only in the umbrella repo, scoped to its own README, and does not cover the registrar, compiler, or plugin repos at all.
- **Origin tokens prove provenance, not truth** — stated explicitly in the plugin's own docs, not glossed over: "an authenticated insider… can still poison L2/L3 content with validly-attested captures."
- **No SAST layered on top of the model-output-JSON-parsing surface** beyond CodeQL — flagged as a gap in Compile's `TEST_AUDIT.md` (dated 2026-05-19, may since be addressed, not re-verified in this pass).
- **No mutation-kill signal on the Compile package** at all — the highest-business-logic-density code (6 compiler passes, provider adapters) has zero mutation testing, deliberately scoped out because the Claude client is mocked in tests.
- **Sensitivity gating is binary and global, not tiered by role** — this is an honest design choice (see Access Control above), not a hidden gap, but worth naming plainly for anyone assuming otherwise: this system segments a shared brain by tenant and by a single confidential/restricted cutline, and nothing finer.

10. Cost & performance

Monthly costs

No repo in this system runs on cloud infrastructure with a metered monthly bill in the traditional sense — Govern's team-bridge API and its embedder/reranker sidecars run on the operator's own tailnet-bound hardware (self-hosted, not cloud-billed), and Compile/Package are npm-published CLIs/plugins with no hosted runtime. The only recurring, quantifiable cost is **LLM inference spend for compiling**:

- **Daily ceiling**: \$1.00/day default hard REFUSE above it (deferred to nightly), with a 300-second debounce/coalescing window to avoid re-billing rapid pushes.
- **Full corpus compile**: estimated \$50-200 per compile (a design-rationale figure from the cost-gate module's own doc comment, not a metered benchmark result from this audit).
- **Per-1M-token pricing** (USD, input/output): Sonnet \$3/\$15, Opus \$15/\$75, Haiku \$0.8/\$4, DeepSeek `deepseek-chat` \$0.28/\$0.42, **MiniMax-M3 \$0.30/\$1.20 — explicitly marked UNVERIFIED, deliberately priced high pending confirmation against a real invoice; per standing instruction this should not be re-proposed autonomously.**
- The cost model is a **heuristic estimate (70/30 input/output token split + per-type historical averages), never a metered actual** — it never calls an LLM to verify, so a pathological compile whose real split differs sharply could over-refuse or under-gate.

Performance

- **Dense retrieval overhead**: figures of +75 ms median / +122.9 ms p95 query latency versus lexical-only appear in this system's history, but only as commit-message measurements on an unmerged branch (`feat/dense-on-by-default`, commits `90c524c`/`e736f88` in bobs-big-brain-registrar) — that branch is confirmed NOT an ancestor of `origin/main` or HEAD. The PR that actually shipped dense retrieval to production, #328 (`46f6bf5`), adds `getDefaultDenseConfig()` but contains no latency measurement of its own. Treat the specific ms figures as directionally informative at best, not as a verified property of shipped code, until re-measured against what's actually live.
- **Dense arm degradation under load**: the same frozen index scored semantic Recall@10 0.9643 idle vs. 0.7679 under load-9.5-on-8-cores, with zero logged errors under the old fail-open-everywhere behavior — this is the exact finding that motivated the fail-open/fail-loud split (§4 decision log).
- **Compile benchmark suite**: a 500-source large-corpus benchmark with a 3× degradation gate covers ingest/lint/render/compile/ask. This audit did not re-run it — reporting its existence and stated scope, not fresh numbers.
- No P50-P99 figures for the read path (search/retrieve end-to-end from a plugin tool call) were found in either research pass; only the dense-arm-specific delta above is directly evidenced, and even that is of contested provenance (see above).

Scaling limits

- **Single-user, single-machine by design for v1** (Compile) — no multi-tenant isolation model in that repo; tenancy is an entirely Govern-side concern (the spool's `tenantId` field).

- **Govern's tenant model is real and code-verified** (see §9), but the whole system is still one shared brain per deployment, not a horizontally-scaled multi-brain architecture — the distributed/merge model (EPIC 1, Dolt-based) is demand-gated, foundation-only.
- **The staleness detector's own numbers give a sense of live-brain scale**: 10,190 active memories in the brain as of its dry run, 1,025 (10.06%) flagged as candidate-stale.
- **Embedder/reranker sidecars are memory-capped**: `bbb-embedder.service` runs with `MemoryMax=3G`.

---

11. Current state

What's working (with citations)

- **The Compile→Govern spool handoff (EPIC 0)** is shipped and load-bearing — `packages/kernel/src/spool.ts` on the Compile side, consumed by Govern's curator.
- **Governed freshness** (incremental recompile + cost gate) is shipped on Compile's `origin/main`, v1.21.0, PR #154 (`af3a7eb`).
- **Fused lexical+dense retrieval** is shipped and is the production default across every Govern surface (API, edge-daemon, MCP server, CLI) and, as of PR #60, the plugin's local mode too — the single most consequential shipped change surfaced by this survey.
- **The 9-rule deterministic policy engine** is shipped, with a documented anti-dormancy gate specifically designed to prevent a registered rule from silently gating nothing — this was the root-cause fix for a real 2026-07-16 incident (~15,000-candidate flood).
- **The audit chain, both the hash-chain writer/verifier and the external git-anchor witness**, is shipped, CI-enforced with both a positive case and an adversarial tamper-detection case on every push. Note: not all four repos' *own* internal docs consistently hold to the "tamper-evident, not tamper-proof/immutable" framing this document requires of itself — see the registrar "immutable" findings in §9's Honest Security Assessment.
- **The dual-mode plugin dispatch** (local vs. team) is shipped, unit-tested at its core predicate, and is the entire reason team mode can ship dependency-free from a marketplace clone.
- **Umbrella's system-graph fitness function** is live, enforced, and the doc and model are in sync as of local HEAD (node/edge counts cross-checked: 50/50 both places).
- **Native-dependency self-containment for the plugin's local mode** is shipped and has now survived two real-world tests (better-sqlite3/fs-ext, then sqlite-vec) of the exact same failure class.

What needs attention, by severity

High: - The flag-vs-reject semantic gap in Govern's policy pipeline (§4, §8.2) — either build a genuine flag-and-promote path or correct the doc comment; leaving it as-is means the codebase's own documentation misdescribes its behavior. - Version/status staleness across three repos' top-level docs simultaneously (registrar README + CLAUDE.md, compiler TEST_AUDIT.md, plugin AGENTS.md, umbrella CHANGELOG.md) — no single fix, but a coordinated documentation pass is overdue. - The registrar's unqualified "immutable" language describing the audit trail in internal docs, code comments, and its public OpenAPI spec — a real brand-honesty violation that no CI gate in that repo currently catches. - The dangling `/usr/bin/ico` global CLI symlink on the operator's dev box — a known, unfixed gap from the 2026-07-19 rename. - 11 open draft PRs in Compile representing a full epic's worth of unmerged, unreviewed near-term architecture.

Medium: - MiniMax-M3 pricing remains unverified against a real invoice (accepted risk, not to be re-proposed autonomously). - The mutation-testing blind spot on Compile's highest-risk package (the 6 compiler passes + provider adapters). - The Compile v1.23.0 release-please PR sitting unmerged with no visible blocker documented. - Manual, unenforced discipline requirements: rebuilding the plugin bundle after `src/` changes; keeping the three native-dependency-vendoring touchpoints in lockstep for any future 4th dependency. - Local git-checkout staleness with no automated session-start guard anywhere in this system. - The dense-retrieval latency figures circulating in this document's own source material trace to an unmerged branch, not the shipped PR — worth re-measuring against what's actually live rather than continuing to cite the unmerged-branch numbers.

Low: - Umbrella's unpinned PyYAML dependency (no lockfile, no version pin in CI). - Automatic Cowork MCP registration remaining unbuilt in the plugin (stated as "Coming," not a broken promise). - The staleness detector's dry-run precision gap (154/1,025 false positives) — correctly gated, not urgent, but blocks the apply step indefinitely until addressed.

Implementation status table

Feature	Layer	Status	Evidence
6-pass compiler + 16-command CLI	Compile	Shipped	`packages/compiler/src/passes/*.t` `packages/cli/src/commands/*.ts`
Provider-agnostic compile (7 built-ins + custom)	Compile	Shipped	`providers.ts`
Governed freshness (incremental + cost gate)	Compile	Shipped	PR #154, v1.21.0
MiniMax `<think>` strip + pricing	Compile	Shipped	PR #183, `cddb2fe`
l13 epic (nightly-distiller hardening, write-lock, honesty lint, quality gate)	Compile	**Draft, unmerged**	11 open PRs, 2026-08-02
v1.23.0 release	Compile	**Pending, not merged**	release-please branch tip `12890a5`
9-rule deterministic policy engine + anti-dormancy gate	Govern	Shipped	`rules/index.ts`, `recommended-policy.ts`
Fused lexical+dense retrieval (RRF k=60)	Govern	Shipped, production default	PR #328/#334
Reranker (Qwen3-0.6B)	Govern	Shipped, **opt-in only**	PR #305

Feature	Layer	Status	Evidence
Staleness detection	Govern	Shipped, **dry-run only**	PR #319
Staleness apply step	Govern	**Not built**	—
Team-bridge HTTP API	Govern	Shipped, deployed	scrypt tokens, tailnet
Distributed multi-node merge (EPIC 1)	Govern	**Foundation-only, primitives shipped, no merge UX**	UUID v5, Ed25519 DAG anchors
Dual-mode dispatch (local/team)	Package	Shipped	`src/index.ts`, `mode.ts`
Dense retrieval in local mode	Package	Shipped 2026-08-04	PR #60 (HEAD)
Auto-capture hook	Package	Built, opt-in, off by default	`hooks/`
Automatic Cowork MCP registration	Package	**Not shipped**	README "Coming"
System-graph fitness function	Umbrella	Shipped, live	`system-graph.yml` + CI
Buzz-routed backup alerting	Umbrella	**Source-shipped, NOT deployed**	origin/main PR #76

---

12. Roadmap

Week 1 (measurable, low-risk cleanup): - Reconcile the three stale-doc findings (registrar README/CLAUDE.md, compiler `TEST_AUDIT.md`, plugin `AGENTS.md` retrieval-roadmap section, umbrella `CHANGELOG.md`) against actual `git log`/`gh pr list` state. Outcome: zero repos with a version number or status claim contradicted by their own git history. - Fix or explicitly document the flag-vs-reject gap in Govern's policy pipeline. Outcome: `recommended-policy.ts`'s doc comment matches `curator.ts`'s actual behavior, one way or the other. - Fix the registrar's unqualified "immutable" language (CLAUDE.md:124, `openapi.ts:36`, `audit-event.ts:5`, `audit-repository.ts:107`, `routes/audit.ts:22`) to say "tamper-evident," and consider extending the umbrella's forbidden-words lint to cover the registrar repo. Outcome: no repo's own docs/code comments/public API spec contradict the trust-model framing this system requires of itself. - Reinstall/repoint `/usr/bin/ico` on the operator's dev box. Outcome: `which ico` resolves.

Month 1 (in-flight work, needs a decision, not new design): - Triage the 11 open draft Compile PRs — merge, close, or explicitly re-scope each one. Outcome: zero "opened same day, still draft a month later" PRs. - Land the v1.23.0 Compile release. Outcome: tag matches `origin/main`. - Deploy the Buzz-routed backup-failure alerting that's been source-shipped since PR #76, with the canary + rollback receipt the commit message says is the gating requirement. Outcome: a real backup failure actually pages someone. - Re-run `/audit-tests` fresh in Compile to replace the 3-month-stale `TEST_AUDIT.md`. Outcome: current, evidence-backed testing posture numbers. - Re-measure dense-retrieval latency against what's actually live in `origin/main`, rather than continuing to cite the unmerged `feat/dense-on-by-default` branch's commit-message numbers. Outcome: a performance claim this document (or any successor) can attribute to shipped code.

Quarter 1 (larger, already-scoped-but-deferred work): - Staleness apply step in Govern, gated on resolving the current 15% false-positive rate against the historical-record exemption logic. - Compile Phase 3 (remote/sync) — still explicitly deferred, no evidence of active work. - Automatic Cowork MCP registration in Package. - EPIC 1 distributed multi-node merge UX (Dolt-based) — demand-gated; foundation primitives already shipped, no scheduled start. - Confirm MiniMax-M3 pricing against a real invoice when/if that becomes a live priority (not to be proposed proactively).

---

13. Quick reference

URLs

Resource	URL
Umbrella (landing)	github.com/intent-solutions-io/bobs-big-brain-umbrella
Compile engine	github.com/jeremylongshore/bobs-big-brain-compiler (npm: `intentional-cognition-os`)
Govern engine	github.com/jeremylongshore/bobs-big-brain-registrar (npm scope: `@qmd-team-intent-kb/*`, unchanged post-rename)
Package (installable plugin)	github.com/jeremylongshore/bobs-big-brain-plugin (npm: `governed-second-brain`)
Retrieve (pinned external)	github.com/tobi/qmd (not owned by this system)

First-week checklist (for anyone picking this system up cold)

1. `git fetch && git log <local>..origin/main` in **every** one of the four repos before trusting any local `main` — this bit two of the four research passes behind this document.
2. Read the umbrella's `system-graph.yml` + rendered topology doc first — it's the one place the cross-repo dependency claims are mechanically checked.
3. Confirm `/usr/bin/ico` resolves; reinstall globally if not.
4. Run `gh pr list --state open` in Compile before describing any near-term feature as live — 11 drafts were open at time of audit.
5. Verify `bbb-embedder`/`bbb-reranker` service status before trusting dense-retrieval quality claims.

6. Read Govern's `apps/api/src/services/search-service.ts` directly (not the README) before making any claim about role-based retrieval filtering — the code and the doc-comment framing diverge in at least one place already found.
7. Check whether `plugin-runtime/governed-brain.cjs` is current relative to `src/` before trusting shipped plugin behavior over source.

Appendix A. Glossary

- **ICO** — internal shorthand for the Compile engine (`bobs-big-brain-compiler`, npm `intentional-cognition-os`, renamed from that name 2026-07-19; bead prefix and npm scope unchanged).
- **INTKB** — internal shorthand for the Govern engine (`bobs-big-brain-registrar`, renamed from `qmd-team-intent-kb` 2026-07-19; npm scope and GHCR image name unchanged).
- **GSB** — the umbrella's cross-repo helper script (`bin/gsb`), also an internal shorthand seen in code comments for the overall system.
- **Spool** — the JSONL handoff format Compile writes and Govern's curator consumes; schema-version-validated at read time. Note: there are two differently-purposed directories both named `spool` in the live brain (`~/.teamkb/spool` — live capture intake — vs. `~/.teamkb/brain/spool` — Compile's default emit target) — a documented trap, not a bug.
- **Receipt** — the combination of a DB row + trace + hash-chained audit JSONL entry + rename-into-place that must precede a wiki file becoming visible.
- **RRF** — Reciprocal Rank Fusion (k=60), the algorithm Govern uses to combine qmd BM25 + native FTS5 + sqlite-vec dense KNN results into one ranked list.
- **BM25** — the lexical ranking algorithm qmd implements; the retrieval backend that shipped first, per the 2026-06-18 decision.
- **EmbeddingGemma-300M** — the small (~320 MB) embedding model backing the dense retrieval arm, chosen deliberately over qmd's heavier 2.2 GB hybrid stack.
- **Origin token** — an HMAC-SHA256 attestation (candidateId+tenantId+capturedAt) minted at `brain_capture`, proving where a capture came from — provenance, not truth.
- **Tamper-evident** — the correct, required framing for this system's audit chain: detectable after the fact, not preventable in advance. Never described in this document as tamper-proof, immutable, or (for local mode) offering non-repudiation — though see §9/§11 for a real, found exception in the registrar's own internal docs and public OpenAPI spec.
- **Local mode / team mode** — the plugin's two runtime dispatch paths, selected by `TEAMKB_API_URL`; local is in-process/single-trust-domain, team proxies to one shared, tailnet-bound brain.
- **AGP / CrossChainPointer** — a defined, structural (not yet operationally checkable) contract binding `agent-governance-plane`'s hash-chained journal events to the tip of this brain's receipt log; described here only as a contract, never as a working cross-chain query, per the umbrella's own documented caveat.

Appendix B. Reference links

- Compile package registry entry: `intentional-cognition-os` on npm
- Govern package scope: `@qmd-team-intent-kb/*` on npm (internal packages, not independently published for public browsing — no reliable link target)

- Package registry entry: `governed-second-brain` on npm
- Retrieve upstream: `@tobilu/qmd` on npm, MIT license, pinned at 2.5.3
- Umbrella's canonical topology doc: `000-docs/020-AT-SMAP-system-dependency-graph.md`
- The retrieval-backend decision record: Govern `000-docs/038-AT-DECR` (in the registrar repo, not this one — no cross-repo link target)

Appendix C. Troubleshooting playbooks

"My plugin's search results feel worse than expected" 1. Confirm which mode is active — local or team (`TEAMKB_API_URL` set?). 2. If local: check `bbb-embedder`/`bbb-reranker` aren't required in local mode (they're Govern-side services); local mode's dense arm is self-contained via `sqlite-vec`. 3. If team: check the API-side embedder service status on the host. 4. Check for a degraded-query signal (`onQueryDegraded`) before assuming a real regression versus load contention.

"A capture I made isn't showing up in search" 1. Check its policy outcome — was it flagged (net effect: not promoted, same as rejected today) or genuinely rejected? 2. Check the sensitivity classification — `confidential`/`restricted` content is hidden from every search caller, including its own author querying as a different role. 3. Check tenant scoping — a capture is only visible to searches scoped to the same tenant.

"I can't tell if a piece of `origin/main` work is actually live" 1. `git log --oneline -20 origin/main` in the repo in question. 2. `gh pr list --state open` — anything still open/draft is not live regardless of how complete it looks. 3. `git merge-base --is-ancestor <commit> origin/main` for any specific commit in question.

"The audit chain verification failed" 1. Distinguish "chain continuity broke" (a real bug — file it) from "someone genuinely tampered with a local event" (the tamper-evidence working as designed). 2. Cross-check against the external git-anchor witness — a local-only chain break without a corresponding anchor mismatch suggests corruption, not malice; a mismatch against a pushed anchor is the actual tamper signal. 3. Never describe a passing local verify alone as proof nothing was altered — a local writer with filesystem access could have edited and re-hashed forward. The anchor comparison is what makes tampering detectable across actors.

Appendix D. Open questions

1. Is `system-graph-sync.yml` actually enforced as a required branch-protection check on the umbrella repo, or only conventionally treated as one? Not verifiable from in-repo files alone.
2. Is there a plan to extend the system-graph fitness-function pattern to also gate the other stale docs found in this audit (registrar README/CLAUDE.md, compiler TEST_AUDIT.md, plugin AGENTS.md)?
3. Are the 11 open draft "l13" epic PRs in Compile sequenced/dependent on each other, or independently mergeable?
4. Has MiniMax-M3 pricing been reconciled against a real invoice since it was written — worth knowing if it happened elsewhere, but not to be proposed as new work here per standing instruction.
5. Is `/usr/bin/ico` intended to be fixed as part of any currently-open PR, or is it strictly a separate, unscheduled ops task?
6. Should Govern's `flag` policy action be wired to a genuine flag-and-promote path, or should the recommended-policy doc comment simply be corrected to describe the current reject-

equivalent behavior honestly? This is a real product decision, not just a docs fix — it changes what “flag” means operationally.

7. Is the `compilation_sources` junction table (Compile) ever getting a writer, or is the current conservative full-recompile-on-ambiguity behavior the accepted permanent state?
8. Is `CHANGELOG_AGGREGATION_TOKEN` (umbrella) still needed now that its only stated consumer (the archived private team-marketplace repo) is retired?
9. Should the registrar’s unqualified “immutable” language (CLAUDE.md:124, `openapi.ts:36`, `audit-event.ts:5`, `audit-repository.ts:107`, `routes/audit.ts:22`) be fixed as a standalone doc pass, or does it warrant extending the umbrella’s `docs-honesty.yml` lint to run against the registrar repo as well, closing the enforcement gap permanently?
10. Should the dense-retrieval latency figures (+75 ms median / +122.9 ms p95) be dropped from future editions of this document entirely, or re-measured against `origin/main` as it stands today, given their only current source is an unmerged branch?